認証API仕様書

メタデータ

- **作成日**: 2025-12-26
- **バージョン**: 1.0.0
- **最終更新**: 2025-12-26
- **担当**: Backend Development Team
- **カテゴリ**: 認証・セッション管理

---

1. 概要

本ドキュメントは、mmdpfプロジェクトの認証機能に関するバックエンドAPI仕様を定義します。

主要機能

- 二段階認証（メールPINコード方式）
- パスワード認証（bcrypt）
- パスワードリセット機能

認証フロー概要

```
[組織] → [ユーザー] → [ログイン] → [パスワード検証]
    → [PINコード生成・メール送信] → [PINコード入力]
    → [セッション生成] → [ロール別画面へ遷移]
```

---

2. 共通仕様

2.1. ベースURL

```
開発環境: http://localhost:3001/api/v1
本番環境: https://api.mmdpf.example.com/api/v1
```

2.2. 共通ヘッダー

リクエストヘッダー

```
Content-Type: application/json
```

レスポンスヘッダー

```
Content-Type: application/json
```

2.3. 共通レスポンス形式

成功レスポンス

```
{
  "success": true,
  "data": {
    // レスポンスデータ
  },
  "meta": {
    "timestamp": "2025-12-26T10:30:00.000Z",
    "requestId": "req_abc123"
  }
}
```

エラーレスポンス

```
{
  "success": false,
  "error": {
    "code": "AUTH_INVALID_CREDENTIALS",
    "message": "ユーザー名またはパスワードが正しくありません",
    "details": []
  },
  "meta": {
    "timestamp": "2025-12-26T10:30:00.000Z",
    "requestId": "req_abc123"
  }
}
```

2.4. 共通エラーコード

コード	HTTPステータス	説明
`AUTH_INVALID_CREDENTIALS`	401	ユーザー名またはパスワードが不正
`AUTH_TOKEN_EXPIRED`	401	セッショントークンの有効期限切れ
`AUTH_TOKEN_INVALID`	401	セッショントークンが不正
`AUTH_2FA_REQUIRED`	401	二段階認証が必要
`AUTH_ACCOUNT_DISABLED`	403	アカウントが無効化されている
`AUTH_RATE_LIMIT_EXCEEDED`	429	レート制限超過
`VALIDATION_ERROR`	400	入力値のバリデーションエラー

---

3. エンドポイント仕様

3.1. POST /api/v1/auth/login

概要

初回ログイン処理。ユーザー名・パスワードを検証し、PINコードをメール送信します。

認証フロー（Step 1/2）

1. ユーザー名 + 組織IDでユーザー検索
2. パスワード検証（bcrypt）
3. PINコード生成（6桁）
4. PINコードをメール送信
5. 仮セッショントークン生成
6. クライアントに返却

リクエスト

HTTPメソッド: `POST`

URL: `/api/v1/auth/login`

ヘッダー:

```
Content-Type: application/json
X-Organization-Id: org_maiml_lab_001
```

ボディ:

```
{
  "username": "user001",
  "password": "SecurePassword123!"
}
```

フィールド定義:

フィールド	型	必須	説明
username	string	○	ユーザー名（1-100文字）
password	string	○	パスワード（8-255文字）

レスポンス

成功時（200 OK）:

```
{
  "success": true,
  "data": {
    "sessionToken": "temp_session_abc123_1735185000",
    "message": "PINコードをメールに送信しました",
    "email": "use***@example.com",
    "expiresIn": 300
  },
  "meta": {
    "timestamp": "2025-12-26T10:30:00.000Z",
    "requestId": "req_abc123"
  }
}
```


フィールド定義:

フィールド	型	説明
sessionToken	string	仮セッショントークン（PINコード入力に使用）
message	string	ユーザー向けメッセージ
email	string	PINコード送信先メールアドレス（マスキング済み）
expiresIn	number	PINコードの有効期限（秒）

エラー時:

HTTPステータス	エラーコード	説明
400	`VALIDATION_ERROR`	入力値が不正
401	`AUTH_INVALID_CREDENTIALS`	ユーザー名またはパスワードが不正
403	`AUTH_ACCOUNT_DISABLED`	アカウントが無効化されている
429	`AUTH_RATE_LIMIT_EXCEEDED`	レート制限超過（5回/15分）
500	`SYSTEM_EMAIL_SEND_FAILED`	メール送信失敗

エラーレスポンス例:


```
{
  "success": false,
  "error": {
    "code": "AUTH_INVALID_CREDENTIALS",
    "message": "ユーザー名またはパスワードが正しくありません",
```

```
    "details": []
  },
  "meta": {
    "timestamp": "2025-12-26T10:30:00.000Z",
    "requestId": "req_abc123"
  }
}
```

実装詳細

バリデーション:

- username: 必須、1-100文字、英数字・アンダースコア・ハイフン
- password: 必須、8-255文字

セキュリティ:

- レート制限: 5回/15分/組織ID
- ログイン試行履歴を記録（`login_history`テーブル）
- Admin権限の場合は監査ログ記録（`admin_audit_log`テーブル）

データベース操作:

1. `organization_user`テーブルからユーザー検索（`organization_id`, `username`）
2. パスワードハッシュ検証（bcrypt.compare）
3. `pin_codes`テーブルにPINコード保存
4. `login_history`テーブルに履歴記録

3.2. POST /api/v1/auth/verify-pin

概要

PINコードを検証し、本セッションを生成します。

認証フロー（Step 2/2）

1. 仮セッショントークンの検証

2. PINコードの検証
3. 本セッション生成（JWT + データベース）
4. HTTPOnly Cookieにセッショントークン設定
5. ユーザー情報返却

リクエスト

HTTPメソッド: `POST`

URL: `/api/v1/auth/verify-pin`

ヘッダー:

```
Content-Type: application/json
Authorization: Bearer temp_session_abc123_1735185000
X-Organization-Id: org_maiml_lab_001
```

ボディ:

```
{
  "pinCode": "123456"
}
```

フィールド定義:

フィールド	型	必須	説明
pinCode	string	○	PINコード（6桁数字）

レスポンス

成功時（200 OK）:

```
{
  "success": true,
  "data": {
    "user": {
      "id": "550e8400-e29b-41d4-a716-446655440000",
      "username": "user001",
```

```
      "email": "user001@example.com",
      "role": "experiment_admin",
      "organizationId": "org_maiml_lab_001",
      "organizationName": "MAIML研究室",
      "displayName": "山田 太郎"
    },
    "session": {
      "token": "maiml_session-abc123_1735185000",
      "expiresAt": "2025-12-27T10:30:00.000Z"
    },
    "redirectUrl": "/experiment-admin"
  },
  "meta": {
    "timestamp": "2025-12-26T10:30:00.000Z",
    "requestId": "req_abc123"
  }
}
```

Set-Cookie ヘッダー:

```
Set-Cookie: maiml_session=maiml_session-abc123_1735185000; HttpOnly; Secure; SameSite=Strict;
Max-Age=86400; Path=/
```

フィールド定義:

フィールド	型	説明
user	object	ユーザー情報
user.id	string	ユーザーID（UUID）
user.username	string	ユーザー名
user.email	string	メールアドレス
user.role	string	ロール
user.organizationId	string	組織ID
user.organizationName	string	組織名
user.displayName	string	表示名
session	object	セッション情報
session.token	string	セッショントークン
session.expiresAt	string	セッション有効期限（ISO 8601）

redirectUrl	string	遷移先URL（ロール別）

エラー時:

HTTPステータス	エラーコード	説明
400	`VALIDATION_ERROR`	入力値が不正
401	`AUTH_TOKEN_INVALID`	仮セッショントークンが不正
401	`AUTH_TOKEN_EXPIRED`	仮セッショントークンの有効期限切れ
401	`AUTH_PIN_INVALID`	PINコードが不正
401	`AUTH_PIN_EXPIRED`	PINコードの有効期限切れ
429	`AUTH_PIN_MAX_ATTEMPTS`	PINコード入力試行回数超過（3回）

実装詳細

バリデーション:

- pinCode: 必須、6桁の数字

セキュリティ:

- PINコード試行回数制限: 3回まで
- PINコード有効期限: 5分
- 検証成功後、PINコードは即座に削除

データベース操作:

1. `pin_codes` テーブルからPINコード検索（`pin_code`, `session_token`）
2. 有効期限・試行回数チェック
3. セッショントークン生成（JWT形式）
4. `pin_codes` テーブルから該当PINコード削除
5. `admin_audit_log` テーブルに監査ログ記録（Admin権限の場合）

3.3. POST /api/v1/auth/resend-pin

概要

PINコードを再送信します。

リクエスト

HTTPメソッド: `POST`

URL: `/api/v1/auth/resend-pin`

ヘッダー:

```
Content-Type: application/json
Authorization: Bearer temp_session_abc123_1735185000
X-Organization-Id: org_maiml_lab_001
```

ボディ: なし

レスポンス

成功時（200 OK）:

```
{
  "success": true,
  "data": {
    "message": "PINコードを再送信しました",
    "email": "use***@example.com",
    "expiresIn": 300
  },
  "meta": {
    "timestamp": "2025-12-26T10:35:00.000Z",
    "requestId": "req_abc124"
  }
}
```

エラー時:

HTTPステータス	エラーコード	説明
401	`AUTH_TOKEN_INVALID`	仮セッショントークンが不正
429	`AUTH_RESEND_LIMIT_EXCEEDED`	再送信制限超過（3回/15分）

実装詳細

セキュリティ:

- 再送信制限: 3回/15分/ユーザー

データベース操作:

1. 既存のPINコードを削除
2. 新しいPINコードを生成・保存
3. メール送信

3.4. POST /api/v1/auth/reset-password-request

概要

パスワードリセット要求。ユーザーにリセット用リンクをメール送信します。

リクエスト

HTTPメソッド: `POST`

URL: `/api/v1/auth/reset-password-request`

ヘッダー:

```
Content-Type: application/json
X-Organization-Id: org_maiml_lab_001
```

ボディ:

```
{
  "username": "user001"
}
```

レスポンス

成功時（200 OK）:

```
{
  "success": true,
  "data": {
    "message": "パスワードリセット用のリンクをメールに送信しました",
    "email": "use***@example.com"
  },
  "meta": {
    "timestamp": "2025-12-26T11:10:00.000Z",
    "requestId": "req_abc127"
  }
}
```

エラー時:

HTTPステータス	エラーコード	説明
400	`VALIDATION_ERROR`	入力値が不正
429	`AUTH_RATE_LIMIT_EXCEEDED`	レート制限超過（3回/15分）

実装詳細

セキュリティ:

- レート制限: 3回/15分/組織ID
- ユーザーが存在しない場合も同じレスポンスを返す（情報漏洩防止）

3.5. POST /api/v1/auth/logout

概要

ログアウト処理。セッショントークン（JWTトークン）を無効化し、Cookieをクリアします。

リクエスト

HTTPメソッド: `POST`

URL: `/api/v1/auth/logout`

ヘッダー:

```
Content-Type: application/json
Authorization: Bearer maiml_session-abc123_1735185000
X-Organization-Id: org_maiml_lab_001
```

ボディ: なし

レスポンス

成功時（200 OK）:

```
{
  "success": true,
  "data": {
    "message": "ログアウトしました"
  },
  "meta": {
    "timestamp": "2025-12-26T11:00:00.000Z",
    "requestId": "req_abc126"
  }
}
```

Set-Cookie ヘッダー（Cookieクリア）:

```
Set-Cookie: maiml_session=; HttpOnly; Secure; SameSite=Strict; Max-Age=0; Path=/
```

エラー時:

HTTPステータス	エラーコード	説明
401	`AUTH_TOKEN_INVALID`	セッショントークンが不正

実装詳細

処理フロー:

1. Authorization ヘッダーからJWTトークンを取得
2. トークンの検証（署名、有効期限）

3. HTTPOnly Cookieをクリア（Max-Age=0）
4. 成功レスポンス返却

セキュリティ:

- JWTトークンは検証のみ（データベースへの記録なし）
- Cookieを完全にクリア
- Admin権限の場合は監査ログ記録

注意事項:

- `user_sessions` テーブルは使用しない（将来実装時に追加）
- 現在はステートレスな実装（JWTトークンのみ）

3.6. POST /api/v1/auth/reset-password

概要

パスワードリセット実行。リセットトークンと新しいパスワードを受け取り、パスワードを更新します。

リクエスト

HTTPメソッド: `POST`

URL: `/api/v1/auth/reset-password`

ヘッダー:

```
Content-Type: application/json
```

ボディ:

```
{
  "resetToken": "reset_abc123_1735185000",
```

```
  "newPassword": "NewSecurePassword456!"
}
```

レスポンス

成功時（200 OK）:

```
{
  "success": true,
  "data": {
    "message": "パスワードを変更しました"
  },
  "meta": {
    "timestamp": "2025-12-26T11:20:00.000Z",
    "requestId": "req_abc128"
  }
}
```

エラー時:

HTTPステータス	エラーコード	説明
400	`VALIDATION_ERROR`	入力値が不正
401	`AUTH_RESET_TOKEN_INVALID`	リセットトークンが不正
401	`AUTH_RESET_TOKEN_EXPIRED`	リセットトークンの有効期限切れ

---

4. セキュリティ実装

4.1. レート制限

エンドポイント	制限	識別子
POST /api/v1/auth/login	5回/15分	組織ID + ユーザー名
POST /api/v1/auth/verify-pin	3回/5分	セッショントークン
POST /api/v1/auth/resend-pin	3回/15分	セッショントークン
POST /api/v1/auth/reset-password-request	3回/15分	組織ID

4.2. PINコード仕様

```
// PINコード生成
const pinCode = crypto.randomInt(100000, 999999).toString();

// PINコード保存
{
  pin_code: pinCode,
  expires_at: new Date(Date.now() + 5 * 60 * 1000), // 5分後
  attempts_count: 0,
  max_attempts: 3
}
```

4.3. セッション有効期限

ロール	有効期限
provider	48時間
system_admin	48時間
data_admin	24時間
experiment_admin	24時間
experiment_worker	12時間
mi_engineer	24時間

---

5. ロール別初期遷移先

ロール	遷移先URL
provider	`/provider`
system_admin	`/system-admin`
data_admin	`/data-admin`
experiment_admin	`/experiment-admin`
experiment_worker	`/experiment-worker`

mi_engineer	`/mi-engineer`

---

6. セッション管理API

6.1. GET /api/v1/sessions

概要

System Adminが自組織のアクティブセッション一覧を取得します。

リクエスト

HTTPメソッド: `GET`

URL: `/api/v1/sessions`

ヘッダー:

```
Content-Type: application/json
Authorization: Bearer maiml_session-abc123_1735185000
X-Organization-Id: org_maiml_lab_001
```

クエリパラメータ: なし

レスポンス

成功時（200 OK）:

```
{
  "success": true,
  "data": {
    "sessions": [
      {
        "tokenId": "550e8400-e29b-41d4-a716-446655440000",
        "userId": "660e8400-e29b-41d4-a716-446655440001",
        "username": "user001",
        "email": "user001@example.com",
        "role": "experiment_admin",
```

```
        "loginAt": "2025-12-26T10:00:00.000Z",
        "expiresAt": "2025-12-27T10:00:00.000Z",
        "ipAddress": "192.168.1.100",
        "userAgent": "Mozilla/5.0...",
        "isCurrentSession": true
      },
      {
        "tokenId": "770e8400-e29b-41d4-a716-446655440002",
        "userId": "880e8400-e29b-41d4-a716-446655440003",
        "username": "user002",
        "email": "user002@example.com",
        "role": "experiment_worker",
        "loginAt": "2025-12-26T09:30:00.000Z",
        "expiresAt": "2025-12-26T21:30:00.000Z",
        "ipAddress": "192.168.1.101",
        "userAgent": "Mozilla/5.0...",
        "isCurrentSession": false
      }
    ],
    "count": 2
  },
  "meta": {
    "timestamp": "2025-12-26T10:30:00.000Z",
    "requestId": "req_abc123"
  }
}
```


フィールド定義:

フィールド	型	説明
sessions	array	セッション一覧
sessions[].tokenId	string	セッションのトークンID（UUID）
sessions[].userId	string	ユーザーID（UUID）
sessions[].username	string	ユーザー名
sessions[].email	string	メールアドレス
sessions[].role	string	ロール
sessions[].loginAt	string	ログイン日時（ISO 8601）
sessions[].expiresAt	string	セッション有効期限（ISO 8601）
sessions[].ipAddress	string	IPアドレス
sessions[].userAgent	string	User-Agent文字列
sessions[].isCurrentSession	boolean	現在のセッションかどうか

count	number	セッション数

エラー時:

HTTPステータス	エラーコード	説明
401	`AUTH_TOKEN_INVALID`	セッショントークンが不正
403	`PERMISSION_INSUFFICIENT`	System Admin権限が必要
500	`SYSTEM_ERROR`	システムエラー
503	`SYSTEM_REDIS_ERROR`	Redisエラー

実装詳細

権限:

- System Admin権限必須

セキュリティ:

- マルチテナント分離: organization_idで自組織のセッションのみ取得
- 現在のセッションには `isCurrentSession: true` フラグを付与

データソース:

- Redisから取得（refreshTokenService経由）
- `user` テーブルと結合してユーザー情報を補完

6.2. DELETE /api/v1/sessions/:tokenId

概要

System Adminが特定のセッションを強制終了します。

リクエスト

HTTPメソッド: `DELETE`

URL: `/api/v1/sessions/:tokenId`

ヘッダー:

```
Content-Type: application/json
Authorization: Bearer maiml_session-abc123_1735185000
X-Organization-Id: org_maiml_lab_001
```

パスパラメータ:

パラメータ	型	必須	説明
tokenId	string	○	終了するセッションのトークンID（UUID）

レスポンス

成功時（200 OK）:

```
{
  "success": true,
  "data": {
    "message": "セッションを終了しました",
    "tokenId": "770e8400-e29b-41d4-a716-446655440002"
  },
  "meta": {
    "timestamp": "2025-12-26T10:30:00.000Z",
    "requestId": "req_abc124"
  }
}
```

エラー時:

HTTPステータス	エラーコード	説明
400	`VALIDATION_ERROR`	自分自身のセッションは終了不可
401	`AUTH_TOKEN_INVALID`	セッショントークンが不正
403	`PERMISSION_INSUFFICIENT`	System Admin権限が必要
404	`RESOURCE_NOT_FOUND`	指定されたセッションが存在しない
500	`SYSTEM_ERROR`	システムエラー
503	`SYSTEM_REDIS_ERROR`	Redisエラー

エラーレスポンス例（自分自身のセッション終了）:

```
{
  "success": false,
  "error": {
    "code": "VALIDATION_ERROR",
    "message": "自分自身のセッションは終了できません",
    "details": []
  },
  "meta": {
    "timestamp": "2025-12-26T10:30:00.000Z",
    "requestId": "req_abc124"
  }
}
```

実装詳細

バリデーション:

- tokenId: 必須、UUID形式
- 自分自身のセッションは終了不可

権限:

- System Admin権限必須

セキュリティ:

- マルチテナント分離: organization_idで自組織のセッションのみ終了可能
- 監査ログ記録（admin_audit_log）

処理フロー:

1. tokenIdでセッションを検索
2. セッションの組織IDが一致するか検証
3. 現在のセッションでないか検証
4. Redisからリフレッシュトークンを削除
5. 成功レスポンスを返却

---

7. 関連ドキュメント

- データベース設計書
- セキュリティ規約
- API設計ポリシー
- バックエンド規約

---

8. 変更履歴

バージョン	日付	変更内容	担当者
1.1.0	2026-02-17	セッション管理API追加（6.1, 6.2）	Cline
1.0.0	2025-12-26	初版作成	Backend Development Team